Проблемы информационной безопасности и защиты персональных данных в корпоративной IT-среде

Вербицкий Данила MO42.2

Данные

что защищаем

Доступ

кто и как использует

Риски

что может пойти не так

Почему это важно для бизнеса

1) Репутация и доверие

2) Непрерывность сервисов

3) Закон и договоры

Классические последствия инцидентов:

- штрафы и юридические риски за нарушения требований к персональным данным
- простои из-за атак (вымогатели, компрометация учетных записей)
- потери клиентов/партнеров и репутационные издержки
- рост затрат: расследование, восстановление, усиление контролей

Ключевые угрозы в IT-корпорации

Фишинг / BEC

кража паролей, токенов, доступ через почту

Ошибки облака / SaaS

публичные ссылки, открытые бакеты, чрезмерные права

Ransomware

шифрование и простои + шантаж публикацией данных

Supply chain

уязвимые зависимости, интеграции, API-доступы

Инсайдер и подрядчики

злоупотребление доступом или ошибки

Жизненный цикл персональных данных

Риск растет вместе с количеством копий и интеграций



Сбор

формы, продукт, HR



Хранение

БД, облако, бэкапы



Обработка

аналитика, саппорт



Передача

подрядчик и, интеграции

Удаление

сроки, право на удаление

контроль:
минимизация, доступ, логи

Где обычно «ломается» защита

- Access sprawl: права выдаются быстро, отзываются медленно
- Нет инвентаризации ПДн: «где храним и кто владелец?»
- Слабая сегментация и разделение обязанностей
- Подрядчики/интеграции: доступ «навсегда» и без мониторинга
- Shadow IT: личные облака, мессенджеры, неконтролируемые SaaS
- Недостаточное логирование: инцидент замечают слишком поздно

Принципы управления доступом (IAM)

Наименьшие привилегии

давать только нужные права и на срок

Разделение обязанностей

критические действия — с контролем второго лица

Персонификация

никаких общих аккаунтов; всё должно быть трассируемо

Роли и группы

централизованно через RBAC/группы, а не «вручную»

Периодический пересмотр

регулярная ревизия и отзыв при смене роли

Логи и аудит

протоколирование и регулярные проверки

Технический контур защиты (минимальный набор)

Идентичность и доступ

- SSO + MFA
- PAM / JIT для админов
- управление секретами и ключами

Защита данных

- шифрование в покое/транзите
- DLP и контроль обмена
- классификация данных

Обнаружение и восстановление

- EDR + патчи
- централизованные логи/SIEM
- бэкапы 3-2-1 и тест восстановления

Процессы: люди + реакция + поставщики

Три процесса, которые «окупаются» быстрее всего:

🎓 Осведомленность сотрудников

- фишинг-тренировки
- правила работы с ПДн
- простые «красные флаги»

🚒 Реагирование на инциденты

- единый канал сообщений
- роли и SLA
- учения + postmortem

Управление рисками поставщиков

- договорные требования
- минимальные права
- регулярный пересмотр доступа

Как защитить персональные данные?

Что можно сделать без больших проектов:

- Включить MFA для почты/VPN/админок и ключевых SaaS
- Ревизия доступов в 3-5 критичных системах: убрать лишнее, закрыть «висящие» аккаунты
- Запретить общие учетки; перейти на роли/группы
- Сделать карту, где хранятся ПДн (хотя бы верхнеуровнево)
- Проверить публичные ссылки и внешние шары в корпоративных облаках
- Настроить централизованные логи входов + базовые алерты
- Проверить бэкапы и один тест восстановления